

Biased Attacker

Three parameters, four profiles, and two different things the word bias names

The page opens with the sentence the whole line exists to act on.

“Real attackers are not expected-utility maximisers. Most models of them are.”

website, Biased Attacker, opening line

The index question underneath it is the mirror of the one next door.

“What makes human attackers uniquely weak? How to best exploit their weakness?”

website, Adversary, the Biased Attacker entry

Next door, Challenging Attacker asks what makes a human adversary hard and answers with adaptivity. Here the same object is read the other way. A human attacker carries systematic deviations from optimal play, and a deviation that is systematic is a deviation a defender can plan against. This file fixes what a deviation is in this project, how it is put into an agent, and how it is measured coming out.

Contents

1	The claim in one page	2
2	Active	2
2.1	The value function and its three parameters	2
2.2	The profiles	4
2.3	Behaviour, and how it is read	5
3	Working	7
4	Peripheral	9
5	The setting, and why it is this one	9
6	What the project holds	10
7	What it is for	11
8	Sources	11

1 The claim in one page

Two ways of modeling an attacker were already available and I did not want either.

“The usual options are both unsatisfying: assume game-theoretic rationality, or hand-write behavioural rules until the agent looks human. The first is wrong about people; the second doesn’t generalise past the cases you wrote down.”

website, Biased Attacker, Bias as a reward, not a rule

“The move here is to put the bias in the reward function.”

website, Biased Attacker, Bias as a reward, not a rule

That is one sentence and it settles three things at once. Bias becomes a continuous parameter rather than a rule, so intensity is expressible. It sits in the objective rather than the policy, so a single training procedure produces every profile and none of them are hand-written. And because the agent still has to learn its policy under that objective, the behavior that comes out is a trajectory through a network rather than a preference over two lotteries. Prospect theory is usually tested by asking a person to pick between fixed options once. Nobody was watching what a biased decision maker does on step fourteen of a break-in, and that is where the differences worth having are.

“Change the curve and the trajectory changes with it. Nothing about the network, the action space, or the objective moved, only how outcomes are valued.”

website, Biased Attacker, Why it matters, with the em dash replaced

2 Active

2.1 The value function and its three parameters

prospect theory value function

Definition: The transform from an objective outcome x to the subjective value the agent actually optimizes:

$$v(x) = x^\alpha \text{ for } x \geq 0, \quad v(x) = -\lambda(-x)^\beta \text{ for } x < 0.$$

It is applied to the reward the environment emits, before the learner sees it.

Distinguishes it from: Reward shaping. Shaping adds a term to steer learning toward a policy you already want and is supposed to leave the optimal policy alone. This changes the optimum. The behavior it produces is worse by the environment’s own reward and that is the intended result.

Operational test: Set $\alpha = \beta = \lambda = 1$. The function collapses to the identity and the agent is the rational baseline. Any profile that does not reduce to the baseline at those values is not this transform.

In my project: Applied to the outcome component of the reward inside a partially observable Markov decision process over CAGE Challenge 2, with the policy trained afresh under each parameter setting.

reference dependence

Definition: The property that outcomes are valued as gains or losses against a reference point rather than in absolute terms. It is what makes the piecewise form legitimate: there has to be a zero for the two branches to be different.

Distinguishes it from: A concave utility function over wealth, which is smooth through zero and has no kink. Loss aversion is the kink, and it cannot be expressed without a reference point.

Operational test: Shift every payoff in the environment by a constant. If the agent's behavior changes, the model is reference dependent.

In my project: The reference point is the per-step reward, so eviction by the defender is what puts the agent in the loss domain. Which is why the defender's choice between removing and restoring changes the biased agent's behavior and not the baseline's.

α , gain curvature

Definition: The exponent on gains. Below one the value function is concave, so each additional unit of reward is worth less than the last, and a payoff of ten is not twice a payoff of five.

Distinguishes it from: β , which does the same job on the loss branch. They are separate exponents and moving one does not move the other.

Operational test: Offer the agent a certain small gain against an uncertain larger one with equal expected value. A concave agent takes the certain one.

In my project: The risk aversion lever. Trained at 0.8, 0.5, and 0.2 with the other two held at one.

β , loss curvature

Definition: The exponent on losses. Below one the loss branch is compressed, so a large loss is felt as less than its size, and failures stop mattering.

Distinguishes it from: λ , which scales the whole loss branch by a constant. β bends it. A high λ and a low β pull in opposite directions and can cancel.

Operational test: Double the penalty on a failed action. An agent with low β barely reacts.

In my project: The risk seeking lever, trained at 0.8, 0.5, and 0.2. The naming is doing work it cannot support, and the entry on risk seeking below says why.

λ , loss aversion multiplier

Definition: The factor by which a loss outweighs a gain of the same size. At $\lambda = 1$ they are symmetric.

Distinguishes it from: Risk aversion. Loss aversion is an asymmetry between two branches; risk aversion is curvature within one. An agent can be loss averse and risk neutral, which is exactly the profile on the page.

Operational test: Compare the agent's response to losing a held host against its response to acquiring an equivalent one. Unequal magnitudes mean $\lambda \neq 1$.

In my project: Trained at 1.5, 2.0, and 2.25. The top value is not arbitrary: 2.25 is the estimate Tversky and Kahneman fitted in 1992, so the strong setting is the human average rather than an

extreme.

2.2 The profiles

rational baseline

Definition: $\alpha = \beta = \lambda = 1.0$. The agent that optimizes the environment's reward as emitted.

Distinguishes it from: An optimal agent. It is the best policy this learner found under the true objective, not a solved one, and every comparison in this line is against it rather than against an optimum.

Operational test: Does the value transform change any number it receives. If not, this is the baseline.

In my project: The control condition in all nine hypothesis tests.

risk averse profile

Definition: Gain curvature below one with the other two parameters at baseline. The agent finds large rewards less attractive than their size warrants and prefers certain intermediate gains.

Distinguishes it from: Cautiousness in the ordinary sense. This agent is not slower or quieter. It takes more hosts than the baseline does, and it takes longer to reach the objective, because intermediate gains have become relatively more valuable and the final prize relatively less.

Operational test: Measure the share of successful exploits directed at low-risk, high-certainty targets. It rises as α falls.

In my project: All three of its hypotheses hold: it prefers low-risk targets, it takes more steps to reach the objective, and it holds a larger compromised host count than the baseline.

loss averse profile

Definition: λ above one with the curvatures at baseline. Losing a held host is felt as more than gaining an equivalent one, so eviction dominates what happens next.

Distinguishes it from: The risk averse profile, which is also cautious and is cautious about a different thing. Risk aversion shows up in target selection before anything is lost. Loss aversion shows up only after the defender acts, and is invisible against a passive defender.

Operational test: Look at the first actions after a defender-induced eviction. A loss averse agent goes back for what it lost instead of moving on.

In my project: Both of its hypotheses hold, and it ends with the largest compromised host count of any profile. The two are the same fact: a policy that spends its steps on recovery accumulates held hosts.

risk seeking profile

Definition: Loss curvature below one with the other two at baseline. Failures are compressed, so the agent stops treating losses as expensive and drives forward.

Distinguishes it from: An aggressive attacker. This one is fast because setbacks are cheap to it, not because rewards are attractive to it. It reaches the objective in fewer steps than the baseline,

holds the smallest and steadiest set of hosts, and after eviction continues lateral movement instead of recovering.

Operational test: Post-eviction action mix. Lateral rather than recovery, and no shift in target preference.

In my project: Three of its four hypotheses hold. The fourth is the useful one.

Risk seeking is not the mirror of risk aversion

The prediction that failed is H9, that the risk seeking agent would prefer high-risk, high-reward targets. It shows no target preference at all, and the reason is in the parameterisation rather than in the agent. Risk aversion is implemented as gain compression, $\alpha < 1$. Risk seeking is implemented as loss compression, $\beta < 1$. Those are not opposites. Making large uncertain rewards more attractive needs gain amplification, $\alpha > 1$, and no run has that.

So the risk seeking profile as trained is a loss-compression profile, and calling it risk seeking promises a target preference the configuration cannot produce. The name should either change or the parameter grid should extend above one on α . Until one of those happens, H9 is not a failed prediction about behaviour; it is a prediction about a condition that was never run.

combined profile

Definition: $\alpha = \beta = 0.88$, $\lambda = 2.25$. Mild concavity on both branches with strong loss weighting, which is the reflection effect: risk attitude that depends on whether the agent is currently in the gain domain or the loss domain.

Distinguishes it from: The three single-parameter profiles, each of which holds one attitude throughout an episode. The combined agent's attitude is state dependent, so it can look cautious early and risk seeking after it has been evicted.

Operational test: Split an episode at the first eviction and measure target preference on each side. A single-parameter profile gives the same answer twice.

In my project: The one profile calibrated to a person rather than to a direction. Those three numbers are the Tversky and Kahneman 1992 fitted values, which makes this the closest thing in the grid to an average human attacker.

The page's table is a corner of the grid

The website gives three rows: Rational at 1.0, 1.0, 1.0; Loss averse at 1.0, 1.0, 2.25; Risk averse at 0.5, 1.0, 1.0. The project grid has eleven settings, three intensities per bias plus the combined profile.

Two things go missing in the reduction. Risk seeking is absent, so the page has no β row at all and a reader concludes that β is unused. And the combined profile is absent, which is the one row a person would want, since it is the only setting fitted to human data. The page shows the corners of the grid and the result that matters most is in the middle of it.

2.3 Behaviour, and how it is read

behavioural fingerprint

“If those deviations are systematic and separable, they are behavioural fingerprints: you could tell

one kind of adversary from another by how they move, and train defenders against a population rather than a single idealised opponent.”

website, Biased Attacker, Why it matters

Definition: A profile of an agent over the behavioural metrics, taken jointly, that identifies which bias it carries.

Distinguishes it from: A signature in the detection sense, which is a pattern in traffic or in a payload. This is a pattern in decisions, and it survives a change of tooling because it is a property of what the attacker values.

Operational test: Two conditions, and the sentence above states them as a conditional for a reason. Systematic: the deviation from baseline is significant across episodes. Separable: two biases do not load on the same metric, so the metric profile identifies the bias rather than merely detecting that there is one.

In my project: Systematic is settled. All the confirmed hypotheses separate their agent from the baseline at $p < 0.001$ under a Mann-Whitney test, with effect sizes read as Cliff’s δ . Separability holds where I have looked: risk aversion loads on target preference, loss aversion on post-eviction recovery, risk seeking on steps to objective. Recovering the bias from the profile is the step after this one.

low-risk target selection

Definition: The share of successful exploits aimed at low-risk, high-certainty targets. The metric that carries risk aversion.

Distinguishes it from: Target value. Risk here is the success probability of the attack, not the worth of the host, and the environment has to present those separately for the metric to mean anything.

Operational test: It is a share, so it needs the environment to hold distinguishable success probabilities. Without that, an agent cannot express a risk preference and the metric reads flat for every profile.

In my project: The clearest single result. It rises as α falls and it is already visible at mild compression.

steps to impact

Definition: The number of steps to the first successful Impact on Op_Server0.

Distinguishes it from: Total reward, which a slow attacker can still accumulate from held hosts. This is the latency to the objective and nothing else.

Operational test: Record the step index of the first successful impact.

In my project: Risk aversion lengthens it, risk seeking shortens it. It is the metric on which the two named-as-opposite profiles actually behave as opposites.

foothold size

Definition: The number of hosts the attacker holds, reported as the value at first impact, as the episode average, and as the episode standard deviation.

Distinguishes it from: Progress. A large foothold is not deep penetration. The loss averse

agent has the largest foothold and is not the fastest to the objective; it is the slowest, because it keeps going back.

Operational test: Count held hosts per step. The standard deviation is the informative one: a low value means the agent is not losing and regaining ground.

In my project: Loss averse largest, risk seeking smallest and with no variance across episodes.

post-eviction lateral movement

Definition: The share of actions immediately after a defender-induced eviction that continue toward new targets rather than recovering the lost host. The metric that carries loss aversion.

Distinguishes it from: Persistence. Both profiles persist. The question is persistence at what, and the split between recovery and advance is the answer.

Operational test: It requires the defender to act, so it is undefined against a passive defender. Any run that reports it has an active defender in it.

In my project: It falls as λ rises. At high λ recovery takes over the whole policy and the agent stops reaching the objective, which is the operating range result below.

operating range

Definition: The interval of a bias parameter within which the intended behavioural signature appears and the agent still functions as an attacker.

Distinguishes it from: The parameter range that is legal. Every value in the grid trains. Not every value produces an agent that reaches Op_Server0.

Operational test: Plot the signature metric and task performance against the parameter on the same axis. The operating range ends where the two curves separate.

In my project: Every bias has one. Moderate risk aversion produces the target preference; strong risk aversion makes the agent chase guaranteed intermediate gains and never arrive. Moderate loss aversion produces the recovery behaviour; strong loss aversion turns the agent into a repair crew. Moderate loss compression produces a steady forward policy; only the strongest setting breaks it. So bias intensity is not a dial that can be turned to the end, and a simulated adversary population should be sampled from inside these intervals rather than from the parameter grid at large.

3 Working

cognitive bias

Definition: A systematic tendency in judgement that departs from logic, probability, or optimal play, and departs the same way each time.

Distinguishes it from: Error. Error is unsigned and averages out. A bias has a direction, which is why it can be a fingerprint and why it can be exploited.

Two senses of bias, one page

The two papers on this page do not use the word for the same thing.

In the modelling paper, a bias is a parameter of the value function. It is continuous, it has an intensity, it is one of three, and it produces its signature over a whole trajectory.

In the empirical paper, a bias is a named effect from the judgement and decision making literature. Default effect and sunk cost fallacy are neither prospect-theory parameters nor expressible as α , β , or λ . The default effect is about which target is chosen first, with no reference point and no gain or loss involved. Sunk cost is about honouring past expenditure, and prospect theory's value function is memoryless over past spend.

So the empirical work does not validate the modelling work, and the page implies it does by listing them under one heading. Two honest ways to fix it. Either add the two observed effects to the model, which needs a state that carries invested effort and a notion of a default option, and neither exists in the current formulation. Or say plainly that the empirical paper establishes that human attackers are biased and the modelling paper picks a different family of biases to simulate. The second is true today. The first is the more interesting project.

default effect

Definition: The tendency to take the preset or first-presented option. In the attacker data, scanning the first or the last system in the network's first layer before anything else.

Distinguishes it from: A reconnaissance heuristic. The systems in question were not more attractive on any observable. They were first and last on the list.

sunk cost fallacy

Definition: Letting unrecoverable past expenditure drive a present decision. In the attacker data, continuing to attack a system that has already failed repeatedly instead of switching.

Distinguishes it from: Rational persistence under uncertainty, where repeated attempts genuinely raise the chance of success. Here they did not: the correlation between a participant's maximum attempts on any system and their score was effectively zero.

HackIT

Definition: The testbed the empirical study ran on. Forty machines, half of them honeypots allocated at random, presented as a two-layer network of twenty reachable systems, with a reconnaissance, an exploitation, and an exfiltration phase, twenty five minutes per round and two rounds.

Distinguishes it from: CybORG, which is an agent training environment. HackIT puts a person at a command line and records what they type, which is where the evidence that human attackers are biased has to come from.

eviction

Definition: The defender taking back a host the attacker held, either by terminating the session or by restoring the machine.

Distinguishes it from: A failed exploit, which costs a step and gains nothing. Eviction removes something already held, so it is the event that puts the agent in the loss domain, and it is the only event that does.

non-stationarity

“The restoring defender makes the environment non-stationary from the attacker’s side, lose the server, lose the reward, re-exploit or fall behind.”

website, Biased Attacker, The setting, with the em dash replaced

Definition: The property that the transition dynamics the attacker faces change over the episode because another agent is acting inside them.

Distinguishes it from: Stochasticity in the exploit outcome, which is fixed and known in distribution. The defender is not noise, it is a second policy.

4 Peripheral

Mann-Whitney U

Definition: A rank-based test of whether two samples come from the same distribution, with no normality assumption.

Pointer: The test behind every hypothesis verdict here, run per profile against the baseline over one thousand evaluation episodes.

Cliff’s δ

Definition: A rank-based effect size, read as negligible below 0.15, small below 0.33, medium below 0.47, and large at or above 0.47.

Pointer: Reported alongside every p value, because a thousand episodes will make almost anything significant and the effect size is what says whether the difference is a fingerprint or a rounding.

invalid action penalty

Definition: The cost applied when the agent selects an action whose preconditions are unmet, leaving the state unchanged.

Pointer: It keeps the action space flat and fixed at forty four discrete choices across all steps, which is what makes stable training possible. It also interacts with β : an agent that compresses losses is an agent that stops minding invalid actions.

5 The setting, and why it is this one

“CAGE Challenge 2, built on CybORG. Thirteen hosts across three subnets, with the operational subnet reachable only through the enterprise layer. The attacker starts with a permanent foothold on User0. Holding a user host pays 0.1 per step, an enterprise or operational server pays 1.0, and Impact on Op_Server0 pays 10.0.”

website, Biased Attacker, The setting

Three properties of that description are doing work and none of them are incidental.

The foothold is permanent. The attacker cannot be removed from User0. So every episode is a recovery problem rather than an intrusion problem, and the loss domain is always reachable.

The payoffs span two orders of magnitude. A user host pays 0.1 and an impact pays 10.0. Gain curvature has nothing to bite on if all the payoffs are the same size, and at this spread a concave agent's preference between accumulating hosts and pressing the objective is a real preference rather than a rounding.

There are two defenders and they differ in exactly one respect. One removes sessions, one restores hosts. Removing takes the session; restoring takes the reward stream with it. That is the difference between an inconvenience and a loss, and it is the reason the loss averse profile is only visible against the restoring defender.

The page adds one condition that the reward table alone does not supply.

“Risk aversion also needs the environment to cooperate: targets are presented with different success probabilities, and risky attacks are penalised, so uncertainty becomes psychologically expensive rather than merely uncertain.”

website, Biased Attacker, Bias as a reward, not a rule

That sentence is a requirement on the environment, not a description of the agent, and it is the one place where this line needed the testbed changed rather than the objective. Without differentiated success probabilities the target-preference metric is undefined, and risk aversion has nowhere to show up.

6 What the project holds

The write-up is the GameSec submission, [2] 2025-2026 Antti_Palvi_RL_based_attacker_behavior_modeling Submission/[June 26th] GameSec/Overleaf/main.tex. What is finished in it: the network scenario, the partially observable formulation with its forty eight dimensional observation vector and forty four action space, the bias formalisation, the experiment design with the full eleven-setting grid, the nine hypotheses, the results, and the sensitivity analysis. What is not: the related work section, the rational baseline description, the training budget, and the discussion.

The code is in the merge repository Code/mentalworld-cyber-network-attackers, source tree sources/rl-based-attacker, from the remote JannatAkbar/RL-based-attacker, held as two notebooks. Its sibling tree in the same repository, sources/cyborg-ibl, belongs to the Challenging Attacker line and its lexicon is mwm_challenging_attacker.tex. The two trees share one file, a README, and the repository's own convention is to keep them separate and put any comparison work in integration/.

They are worth comparing, and that comparison is the open work on this branch. The Challenging Attacker line answers what a defender cannot learn to counter, and the answer is adaptivity. This line answers what a defender could plan against, and the answer is a bias with a direction. Both attackers sit on the same scenario, with the same three subnets, the same gateway, the same target, and the same three reward magnitudes. Neither has been run against the other's defender.

“The trajectories shown are illustrative of the mechanism. Measured results are still being written up.”

website, Biased Attacker, closing note under Why it matters

That caveat is about the animation on the page and it should stay there until the figures are the measured ones. The numbers in this file are from the submission, not from the page.

7 What it is for

The index question asks how to best exploit the weakness, and the honest answer at this point is in two parts.

The part that is done: a population. Training a defender against one idealised opponent produces a defender that has learned one opponent. A parameterised family of biases produces a population of adversaries that differ in ways a defender can actually meet, generated from one training procedure rather than written by hand, and sampled from inside the operating ranges so that every member is still a functioning attacker.

The part that is not: identification. If the fingerprints are separable, a defender watching a live trajectory could recover which bias it is facing and act on it. Loss aversion predicts an attacker that will come back for what it lost, and an attacker that will come back is an attacker you can decide where to let it come back to. The empirical side already points the same way, at the coarser grain of observed effects: participants converged on the first and last systems in the first layer, so a defender who knows that knows where to put the honeypots.

The empirical result also fixes how strong these effects are in people, and it is not subtle. Ninety percent of participants opened on the first or the last system. Around ninety percent kept attacking a system that had already failed them, repeatedly, in both rounds, for no gain in score. The modelling side of this line is worth doing because that is what the behaviour of real attackers looks like.

The cluster page states the connection to the other half of the branch in one line, and it is the sentence this line and its neighbour are both instances of: recovering a hidden type from behaviour, while the other party adapts.

8 Sources

- Every quoted sentence above is from the website, either `opponent-agent-modeling/bias/biased-attacker.md`, its parent `bias/README.md`, or the cluster `README.md` and `next.md`. The locator on each one says which. Two locators record that an em dash in the original was replaced by a comma. Nothing else in any quotation was changed, including the British spellings.
- Akbar, J., Oulasvirta, A., Aggarwal, P., and Du, Y. Simulating Attackers with Cognitive Biases using Reinforcement Learning. GameSec submission, June 2026. Read in full. The parameter grid, the nine hypotheses, the behavioural metrics, the statistical tests, and the sensitivity results are from it.
- Aggarwal, P., Nowmi, S. R., Du, Y., and Gonzalez, C. Evidence of Cognitive Biases in Cyber Attackers from An Empirical Study. *HICSS* 57, 2024, pages 934 to 941. doi:10.24251/HICSS.2024.114. Read in full. The default effect, the sunk cost fallacy, the HackIT setting, and the two proportions are from it.
- Tversky, A., and Kahneman, D. 1992, for $\alpha = \beta = 0.88$ and $\lambda = 2.25$ as the fitted human values, cited in the GameSec file as the reference point the grid brackets.

- The three tiers, the four fields, and the rule that a term whose two uses disagree belongs inside its own entry are from `_side/_lexicons/lexicon_method.tex`.